Compliance Annotation

Helix Data Platform, Inc.

Framework: SOC 2 | Compliance Level: Partially Compliant / Significant Risks

---

Finding 1: [VIOLATION] Governance & Security Oversight (CC1)

Security is overseen by a VP of Engineering rather than a dedicated CISO. There is no formal Security Steering Committee; security matters discussed at a "monthly engineering all-hands meeting" lack the requisite structure, documented minutes, and cross-functional executive oversight required for SOC 2 governance.

References: SOC 2 CC1.2, CC1.3

Finding 2: [VIOLATION] Stale Risk Assessment & Accepted Risk Review (CC3)

The comprehensive risk assessment was last conducted in January 2023. SOC 2 requires assessments at least annually or upon significant environmental changes. Furthermore, the 11 "accepted risks" have not been reviewed for over two years, failing to ensure the risk treatment plans remain appropriate.

References: SOC 2 CC3.1, CC3.2

Finding 3: [VIOLATION] Excessive Access Revocation Latency (CC6)

Access revocation for terminated personnel typically occurs "within one week" of notification. For a production data platform, revocation should be near-instantaneous (typically within 24 hours). This delay creates a significant window for unauthorized access or insider threats.

References: SOC 2 CC6.5

Finding 4: [VIOLATION] Use of Shared Service Accounts (CC6)

The use of shared service accounts for deployment pipelines, database maintenance, and monitoring integrations undermines the principle of individual accountability. This practice reduces the precision of audit logs and complicates the forensic investigation of unauthorized system changes.

References: SOC 2 CC6.1

Finding 5: [CONCERN] Inadequate Data Isolation and Encryption Strategy (C1, CC6)

Data at rest relies on AWS-managed keys (SSE-S3) without tenant-specific encryption or customer-managed keys (CMKs). Relying solely on "application-level row filtering" for multi-tenant isolation, without cryptographic separation, increases the risk of cross-tenant data exposure.

References: SOC 2 CC6.1, C1.1

Finding 6: [VIOLATION] Lack of Formal Change Control & CAB (CC8)

There is no formal Change Advisory Board (CAB). While continuous deployment is utilized, the absence of a structured approval process or compensating controls for "urgent fixes"—which can be deployed by any senior engineer—bypasses essential segregation of duties.

References: SOC 2 CC8.1

Finding 7: [VIOLATION] Stale Incident Response Runbook & Case-by-Case Notifications (CC7)

The incident response runbook has not been updated since June 2023. Additionally, customer notifications are handled on a "case-by-case basis" by the VP of Engineering, indicating a lack of defined, objective Service Level Agreements (SLAs) for security incident disclosure.

References: SOC 2 CC7.3, CC7.4

Finding 8: [VIOLATION] Lack of Geographic Redundancy for Backups (A1)

Automated daily backups are stored in the same AWS region as the production environment. This failure to maintain geographic redundancy exposes the organization to catastrophic data loss in the event of a regional AWS service failure.

References: SOC 2 A1.2

Finding 9: [VIOLATION] Untested Disaster Recovery (A1)

The disaster recovery plan has not been tested since its initial creation in 2022. SOC 2 requires regular (at least annual) testing to ensure that Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets are operationally achievable.

References: SOC 2 A1.2

Finding 10: [VIOLATION] Incomplete Vendor Management Lifecycle (CC9)

Helix lacks a recurring annual vendor review process. While initial assessments are performed, SOC 2 requires the periodic reassessment of critical vendors' security postures (e.g., reviewing their updated SOC 2 Type II reports) throughout the engagement.

References: SOC 2 CC9.2

Finding 11: [VIOLATION] Processing Integrity Gaps & Lack of Alerting (PI1)

There are no end-to-end data integrity verification mechanisms for the ETL pipeline. Furthermore, batch processing failures log errors but do not trigger automated alerts to operators, creating a risk that processing failures remain undetected for extended periods.

References: SOC 2 PI1.1